

HiveForce Labs

THREAT ADVISORY

VULNERABILITY REPORT

VMware tackles security flaws in ESXi and vRealize

Date of Publication

December 16, 2022

Admiralty Code

A1

TA Number

TA2022302

Summary

First Seen: December 13, 2022

Affected Products: ESXi , Fusion, VMware Workspace ONE Access, and vRealize,

Impact: remote arbitrary code and privilege escalation

⚙ CVEs

CVE	NAME	PATCH
CVE-2022-31702	VMware vRealize Network Insight (vRNI) command injection vulnerability	✓
CVE-2022-31703	VMware vRealize Network Insight (vRNI) directory traversal vulnerability	✓
CVE-2022-31700	Authenticated Remote Code Execution Vulnerability	✓
CVE-2022-31701	Broken Authentication Vulnerability	✓
CVE-2022-31705	Heap out-of-bounds write vulnerability	✓
CVE-2022-31707	VMware vRealize Operations (vROps) privilege escalation vulnerability	✓
CVE-2022-31708	VMware vRealize Operations (vROps) contains an access control vulnerability	✓

Vulnerability Details

VMware addressed security weaknesses to address a critical-severity vulnerability affecting ESXi, Workstation, Fusion, and Cloud Foundation, as well as a critical-severity command injection flaw impacting vRealize Network Insight. CVE-2022-31705 is a heap out-of-bounds write vulnerability that allows a local privileged user on the guest OS to execute arbitrary code. Exploiting this vulnerability could potentially compromise the host operating system.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-31702	vRealize Network Insight: 6.7.3-6.0.0	cpe:2.3:a:vmware:vrealize_network_insight:-:*:*:*:*:*	CWE-78
CVE-2022-31703	vRealize Network Insight: 6.7.3-6.0.0	cpe:2.3:a:vmware:vrealize_network_insight:-:*:*:*:*	CWE-22
CVE-2022-31700	VMware Workspace ONE Access: 21.08.0.0-22.09.0.0 & VMware Identity Manager: 3.3.6	cpe:2.3:a:vmware:vmware_workspace_one_access:-:*:*:*:*:* cpe:2.3:a:vmware:identity_manager:-:*:*:*:*	CWE-20
CVE-2022-31701	VMware Workspace ONE Access: 21.08.0.0 - 21.08.0.1 & VMware Identity Manager: 3.3.6	cpe:2.3:a:vmware:vmware_workspace_one_access:-:*:*:*:*:* cpe:2.3:a:vmware:identity_manager:-:*:*:*:*	CWE-284
CVE-2022-31705	VMware Fusion: 12.2.0 - 12.2.4, VMware Workstation: 16.0 - 16.2.4 & VMware ESXi: 8.0	cpe:2.3:a:vmware:vmware_fusion:-:*:*:*:*:* cpe:2.3:a:vmware:vmware_workstation:-:*:*:*:*:* cpe:2.3:o:vmware:vmware_esxi:-:*:*:*:*	CWE-787
CVE-2022-31707	VMware vRealize Operations: 8.10- 8.0.0	cpe:2.3:a:vmware:vrealize_operations:-:*:*:*:*	CWE-269
CVE-2022-31708	VMware vRealize Operations: 8.10- 8.0.0	cpe:2.3:a:vmware:vrealize_operations:-:*:*:*:*	CWE-284

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Details' on the following pages.



Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence
<u>TA0008</u> Lateral Movement	<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1078</u> Valid Accounts
<u>T1098</u> Account Manipulation	<u>T1203</u> Exploitation for Client Execution	<u>T1190</u> Exploit Public-Facing Application	<u>T1574</u> Hijack Execution Flow
<u>T1210</u> Exploitation of Remote Services	<u>T1059</u> Command and Scripting Interpreter		



Patch Links

<https://www.vmware.com/security/advisories/VMSA-2022-0031.html>

<https://www.vmware.com/security/advisories/VMSA-2022-0032.html>

<https://www.vmware.com/security/advisories/VMSA-2022-0033.html>

<https://www.vmware.com/security/advisories/VMSA-2022-0034.html>



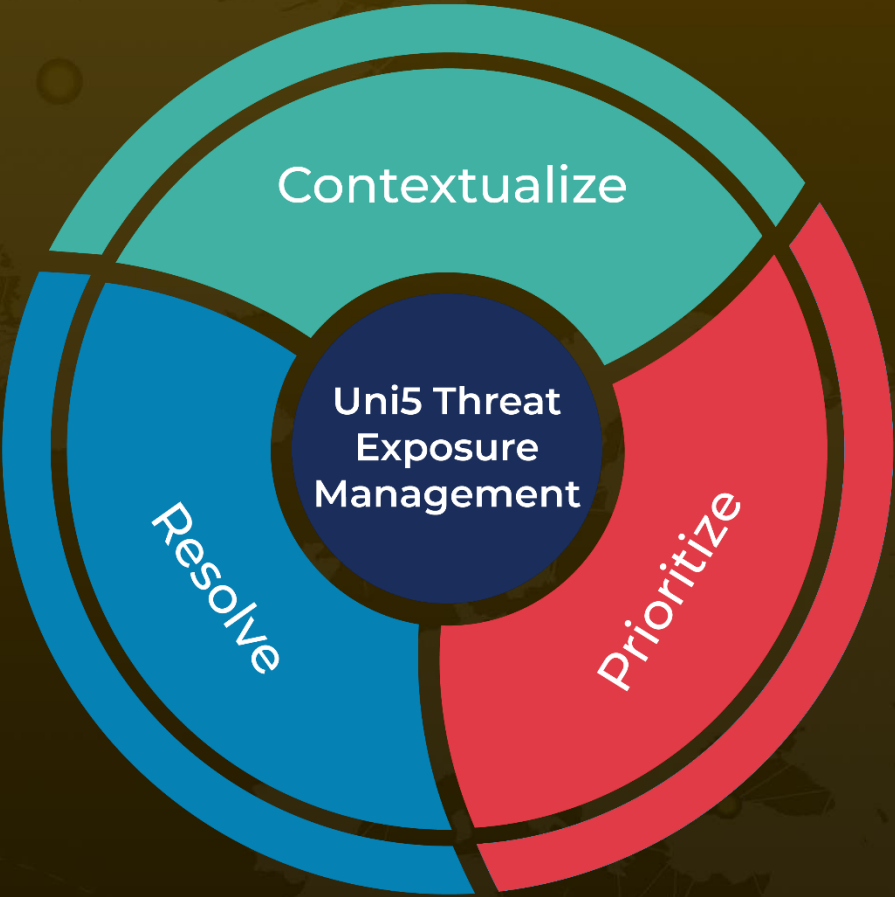
References

<https://www.vmware.com/security/advisories.html>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 16, 2022 • 3:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com